Escala

Owner: Diogo Pereira
Reviewer:
Contributors: Diogo Pereira, Diogo Sousa, Pedro Costa, Diogo Costa
Date Generated: Sun Nov 01 2026

Executive Summary

High level system description

Threat model of Escala (LABDSOF 2026/27). Summarised on Confluence page 09 · Security and Privacy Assessment. Threats T-01 to T-14 match page 09.

Summary

Total Threats	20
Total Mitigated	1
Total Open	19
Open / Critical Severity	0
Open / High Severity	13
Open / Medium Severity	5
Open / Low Severity	1

1 · Application data flow

Users, services, data stores and external services of Escala in one environment (dev, QA or production).

1 · Application data flow

Member (volunteer, cadet, professional) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Supervisor (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Admin (commander) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Dispatcher (on-shift board, read only) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Traefik ingress (TLS) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

web (nginx + Angular PWA) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T-01 · Mocked sign-in lets anyone pick a privileged user	Spoofing	High	Open		With mocked sign-in, anyone with the link picks the supervisor or admin user. Components: web, escala-api.	Only synthetic data while sign-in is mocked; roles still checked on every endpoint; real authentication before any real data. Accepted for the MVP (§6.6 footnote). SCRUM-63.

escala-api (Process)

Description: Published schedule, members, unavailability, swaps, presence, cover, audit.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T-01 · Mocked sign-in lets anyone pick a privileged user	Spoofing	High	Open		With mocked sign-in, anyone with the link picks the supervisor or admin user. Components: web, escala-api.	Only synthetic data while sign-in is mocked; roles still checked on every endpoint; real authentication before any real data. Accepted for the MVP (§6.6 footnote). SCRUM-63.
3	T-03 · Member acts on someone else's shift	Tampering	High	Open		A member edits the request to swap or free someone else's shift, or to accept a cover for their own slot.	The server takes the member from the session, never from the request body, and checks that the shift is theirs; accepting a cover for one's own slot is refused. Tests with SCRUM-68 and SCRUM-73.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	T-06 · Member or supervisor denies an action	Repudiation	Medium	Open		A member says they never accepted a swap or cover; a supervisor says they never published a change.	Append-only audit records with who, what and when. TC-SCRUM-69-04.
5	T-08 · Member reads other members' data	Information disclosure	Medium	Open		A member reads other members' contacts, unavailability or cover balance through the API.	Responses to members carry only names and functions of others; no reason field; contacts and cover balance only for the owner. Tests with SCRUM-67 and SCRUM-82.
6	T-12 · Privileged endpoints or prompt injection	Elevation of privilege	High	Open		A member calls supervisor or admin endpoints directly; a message to the AI tries to make the model act (prompt injection).	Role checked on the server (403); the model runs with no tools in an empty folder, returns only the period schema, and the member confirms every proposal. TC-SCRUM-63-02, TC-SCRUM-75-01.

escala-db (PostgreSQL) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T-04 · Two members take the same cover	Tampering	Medium	Open		Two members accept the same cover at once and both are placed in the slot.	Only the first stored answer takes the slot (transaction with a uniqueness constraint). TC-SCRUM-73-02.

RabbitMQ (escala.events, DLQ) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	T-02 · Fake messages published to the broker	Spoofing	High	Mitigated		A process on the network publishes fake eligibility results or requests to the broker.	Broker reachable only inside the cluster; one broker user per service, allowed only on its own queues (infra/rabbitmq/setup.sh; internal service only). No test yet.

elegibilidade- worker (Process)

Description: Function checks, free-text extraction, IPMA poll.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T-05 · Wrong certification lets an unqualified member drive	Tampering	High	Open		A wrong or altered certification lets an unqualified member drive.	Only the admin edits certifications; every change is audited; the worker re-checks validity at the shift date (RN03). SCRUM-77, TC-SCRUM-69-02.
10	T-10 · IPMA or the AI slow or down	Denial of service	Medium	Open		IPMA or the AI is slow or down and blocks the supervisor or the member.	Timeouts; IPMA shows the last value with its age; AI off by flag or after 10 s falls back to the form. TC-SCRUM-75-03, TC-SCRUM-76-02.

elegibilidade-db (PostgreSQL) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Claude Code CLI (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	T-11 · AI usage limit exhausted	Denial of service	Low	Open		Many AI requests use up the subscription's usage limit, so the AI stops for everyone.	At most 10 AI requests per member per hour (configurable); the form always works without the AI. Test with SCRUM-75.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	T-12 · Privileged endpoints or prompt injection	Elevation of privilege	High	Open		A member calls supervisor or admin endpoints directly; a message to the AI tries to make the model act (prompt injection).	Role checked on the server (403); the model runs with no tools in an empty folder, returns only the period schema, and the member confirms every proposal. TC-SCRUM-63-02, TC-SCRUM-75-01.

Backups volume (pg_dump, 7 days) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	T-14 · Backups lost with the cluster	Denial of service	Medium	Open		The nightly pg_dump files are kept on a volume in the same cluster as the databases, so losing the node loses the databases and the backups.	In place: nightly backups kept 7 days on their own volume. Recommended: copy them outside the cluster (another host or object storage), or record the risk as accepted for the academic demonstration.

Anthropic (Claude Haiku) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

IPMA open data (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTPS (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTPS (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTPS (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTPS (read) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTP (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

REST /api (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

SQL (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Requests (outbox) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	T-07 · Free text with a health detail leaks	Information disclosure	High	Open		Free text with a health or family detail leaks through logs, the dead-letter queue or the AI provider.	Free text never logged; deleted on confirmation or after 24 h; dead-letter messages deleted after 7 days; only text and reference date sent to the model; synthetic text only in demonstrations. TC-SCRUM-75-04.

Results (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Requests (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Results (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

SQL (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Text + date / periods (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Prompt (no names) / answer (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	T-07 · Free text with a health detail leaks	Information disclosure	High	Open		Free text with a health or family detail leaks through logs, the dead-letter queue or the AI provider.	Free text never logged; deleted on confirmation or after 24 h; dead-letter messages deleted after 7 days; only text and reference date sent to the model; synthetic text only in demonstrations. TC-SCRUM-75-04.

Hourly poll (RCM, warnings) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

pg_dump (Data Flow)

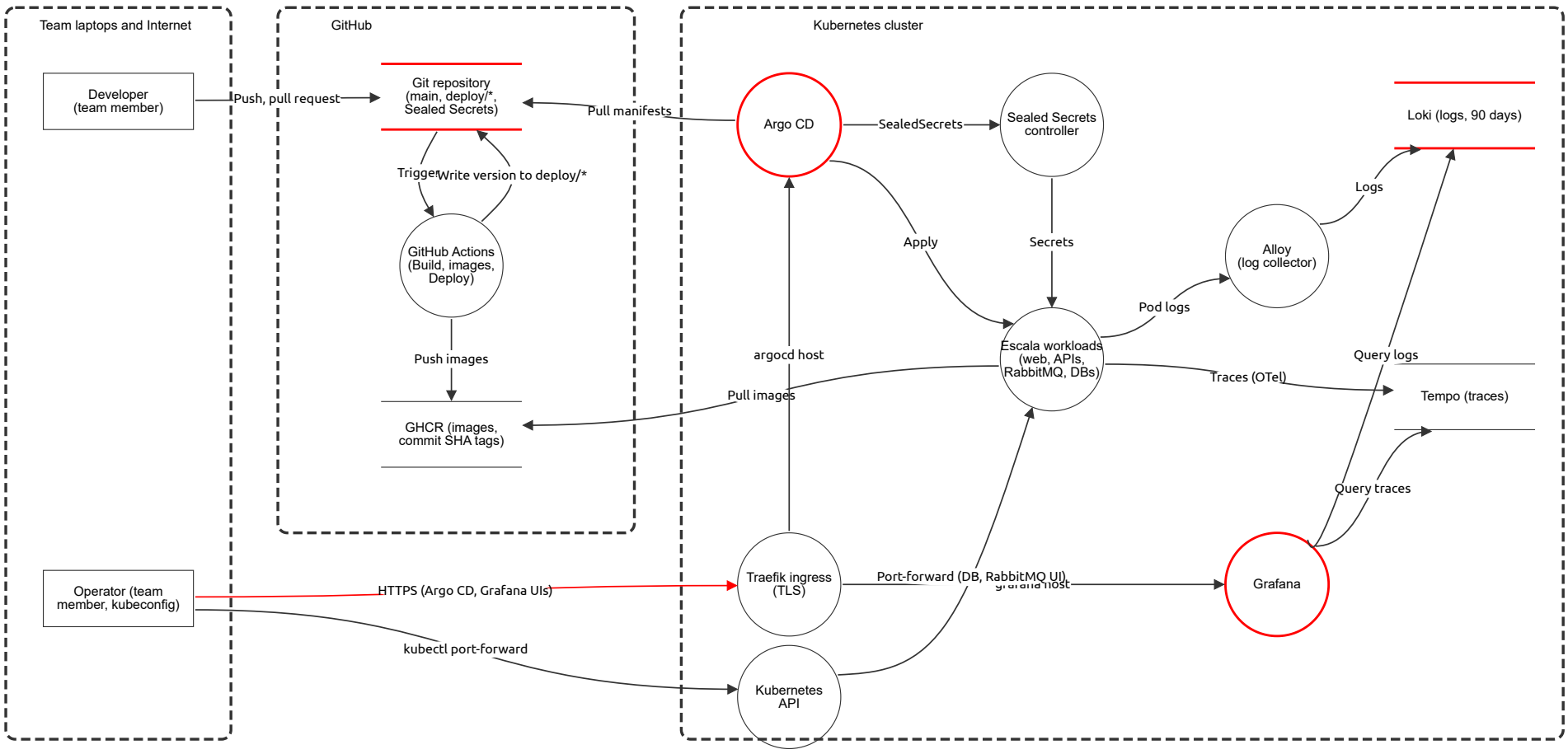
Number	Title	Type	Severity	Status	Score	Description	Mitigations

pg_dump (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2 · Delivery and operations

How code reaches the cluster (GitOps with Argo CD) and how the team operates it (observability, port-forward).



Escala · delivery and operations (main, 2026-10-31)
GitOps: CI never sends secrets to the cluster

2 · Delivery and operations

Developer (team member) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Operator (team member, kubeconfig) (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Git repository (main, deploy/*, Sealed Secrets) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
16	T-09 · Secret committed to the repository	Information disclosure	High	Open		A secret (database, broker or CLI login) is committed to the repository.	Sealed Secrets only in Git; secret scanner in CI that fails the build (RNF07): not implemented yet (Diogo Costa).

GitHub Actions (Build, images, Deploy) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

GHCR (images, commit SHA tags) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Argo CD (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	T-13 · Brute force on exposed admin UIs	Spoofing	High	Open		Argo CD (escala-argocd.duckdns.org) and Grafana (escala-grafana.duckdns.org) are reachable from the Internet with a password login; a guessed or default password gives control of deployments or access to logs.	In place: TLS on both hosts; Grafana admin credentials in a Sealed Secret and sign-up turned off. Recommended: change the initial Argo CD admin password and delete its secret, and restrict both UIs by IP allow-list or single sign-on.

Sealed Secrets controller (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Escala workloads (web, APIs, RabbitMQ, DBs) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Traefik ingress (TLS) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Grafana (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	T-13 · Brute force on exposed admin UIs	Spoofing	High	Open		Argo CD (escala-argocd.duckdns.org) and Grafana (escala-grafana.duckdns.org) are reachable from the Internet with a password login; a guessed or default password gives control of deployments or access to logs.	In place: TLS on both hosts; Grafana admin credentials in a Sealed Secret and sign-up turned off. Recommended: change the initial Argo CD admin password and delete its secret, and restrict both UIs by IP allow-list or single sign-on.

Alloy (log collector) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Loki (logs, 90 days) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
18	T-07 · Free text with a health detail leaks	Information disclosure	High	Open		Free text with a health or family detail leaks through logs, the dead-letter queue or the AI provider.	Free text never logged; deleted on confirmation or after 24 h; dead-letter messages deleted after 7 days; only text and reference date sent to the model; synthetic text only in demonstrations. TC-SCRUM-75-04.

Tempo (traces) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Kubernetes API (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Push, pull request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Trigger (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Write version to deploy/* (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Push images (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Pull manifests (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

SealedSecrets (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Apply (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Secrets (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Pull images (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Pod logs (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Logs (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Traces (OTel) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Query logs (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Query traces (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTPS (Argo CD, Grafana UIs) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
20	T-13 · Brute force on exposed admin UIs	Spoofing	High	Open		Argo CD (escala-argocd.duckdns.org) and Grafana (escala-grafana.duckdns.org) are reachable from the Internet with a password login; a guessed or default password gives control of deployments or access to logs.	In place: TLS on both hosts; Grafana admin credentials in a Sealed Secret and sign-up turned off. Recommended: change the initial Argo CD admin password and delete its secret, and restrict both UIs by IP allow-list or single sign-on.

argocd host (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

grafana host (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

kubectl port-forward (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Port-forward (DB, RabbitMQ UI) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations